

Script-Controlled ACL – Restrict Record Access Based on Field Value

2. Requirement Analysis

2.1 Functional Requirements

- The system shall authenticate users before checking record access.
- The system shall identify the current user's role or department.
- The system shall read the required field value from the target record.
- The system shall execute an ACL script before allowing the requested operation.
- The system shall allow or deny access based on the script result.
- The system shall record important denied-access events for auditing.

2.2 Non-Functional Requirements

- Security: access decisions must be enforced on the server side.
- Performance: ACL checks should execute quickly for normal requests.
- Maintainability: rules should be easy to modify.
- Reliability: unauthorized requests must not bypass the ACL.
- Usability: authorized users should see only records they are permitted to use.

2.3 Inputs

- User ID and authenticated session.
- User role or department.
- Record ID.
- Field value used for access control.
- Requested operation such as View, Insert, Update, or Delete.

2.4 Outputs

The ACL script returns an access decision such as ALLOW or DENY. The application then continues the operation or blocks it accordingly.

2.5 Basic Rule

Example rule: if record.Department equals currentUser.Department, allow access; otherwise deny access. Additional conditions can be combined when required.